

Security Assessment Findings Report

for

zero.webappsecurity.com

Date of Test: 11/07/2026

Tools Used: Nmap, OWASP ZAP, Chrome DevTools

Confidentiality Statement

This document is the exclusive property of the assessed organization and the tester. It contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both parties. This document may be shared with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A vulnerability assessment is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period. Time-limited engagements do not allow for a full evaluation of all security controls. This assessment prioritized the identification of the weakest security controls an attacker would exploit. It is recommended to conduct similar assessments on a regular basis, using internal or third-party assessors, to ensure the continued success of security controls.

Assessment Overview

This assessment evaluated the security posture of zero.webappsecurity.com against current industry best practices, including reconnaissance, vulnerability scanning, and manual verification. Testing performed is broadly based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment and the OWASP Testing Guide.

Assessment Components

Network reconnaissance and service enumeration were performed with Nmap. Automated web application scanning was performed with OWASP ZAP. Manual verification of findings, including inspection of HTTP requests, responses, and browser security indicators, was performed with Chrome DevTools.

Finding Severity Ratings

The following table defines the levels of severity used throughout this document to assess vulnerability and business risk.

Severity	Definition
High	Exploitation is straightforward and could cause elevated privileges, data loss, or downtime. Patch as soon as possible.
Medium	Vulnerabilities exist and may require additional steps to exploit, but they weaken overall defenses. Patch after high-priority issues are resolved.
Low	Vulnerabilities are not directly exploitable but reduce the organization's attack surface. Patch during routine maintenance.

Scope

Assessment	Details
External vulnerability assessment	http://zero.webappsecurity.com

Executive Summary

On 11/07/2026, a vulnerability assessment was conducted on <http://zero.webappsecurity.com>. The tools used for scanning were Nmap, OWASP ZAP, and Chrome DevTools. By combining network reconnaissance and automated web scanning, five findings were identified affecting the confidentiality and integrity of the application and its users. It is recommended that these vulnerabilities be addressed as soon as possible, as they are easily found through basic reconnaissance.

Attack Summary

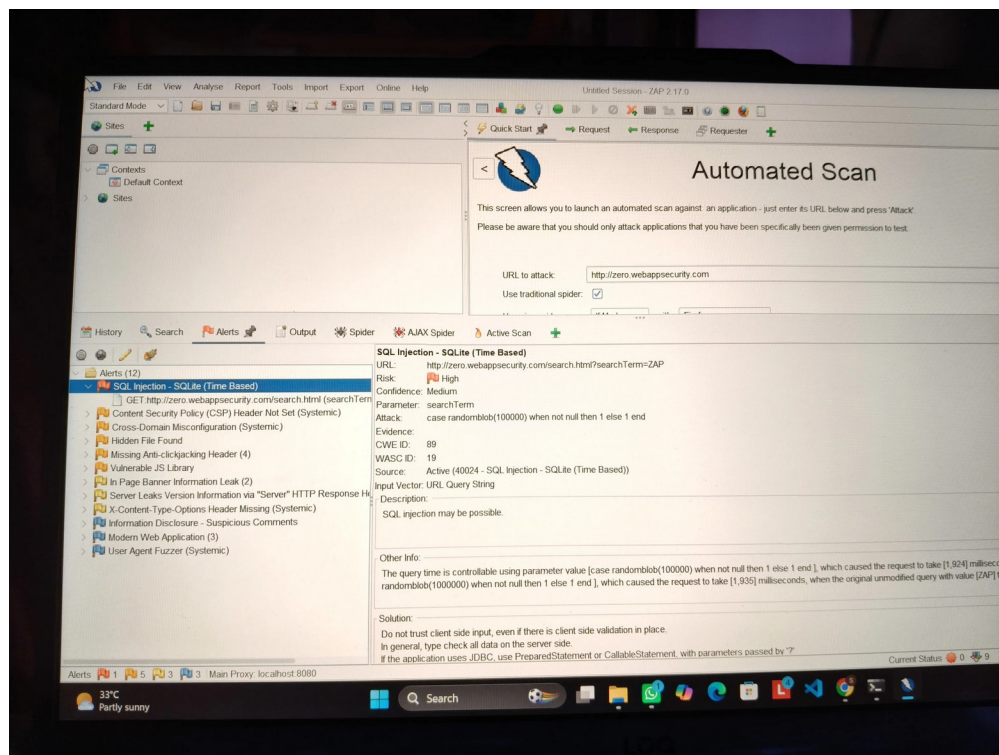
Sl. no	Action	Recommendation	Severity
1	SQL Injection vulnerability found in the search function	Implement input validation and parameterized queries	High
2	Outdated, expired SSL/TLS encryption (SSLv2 supported, certificate expired)	Renew certificate; disable SSLv2 and legacy ciphers; force HTTPS	High
3	Insecure connection over HTTP and missing security headers	Enforce HTTPS; add CSP, X-Frame-Options, X-Content-Type-Options	Medium
4	Server software version disclosure and risky HTTP methods enabled	Suppress version banner; disable unused HTTP methods	Medium
5	Outdated JavaScript library (jQuery 1.8.2) in use	Upgrade third-party JavaScript libraries on a regular patch cycle	Medium

Penetration Test Findings

1) SQL Injection in the Search Function (High)

Description	The search function is vulnerable to SQL injection (a common attack vector that uses malicious input to manipulate the backend database). A crafted test parameter caused the server to take significantly longer to respond, proving the query executes attacker-controlled logic against the database.
Impact	High
System	http://zero.webappsecurity.com/search.html?searchTerm=ZAP

Proof of concept:



OWASP ZAP automated scan: SQL Injection (SQLite, Time Based) alert on the search parameter, rated High risk, CWE-89

Recommendation:- Implement input validation and parameterized queries (prepared statements) so user input is never concatenated directly into SQL statements. Enforce least-privilege database accounts and validate input types and formats server-side.

2) Outdated, Expired SSL/TLS Encryption (High)

Description	The server still accepts SSLv2, an encryption protocol that is over 25 years old and known to be broken, offering only weak export-grade ciphers
--------------------	--

	(DES/RC4/MD5). In addition, the site's SSL certificate expired on 04 May 2022.
Impact	High
System	https://zero.webappsecurity.com (port 443)

Proof of concept:

```

vishal@LAPTOP-3VUES001:~$ nmap -sV -sC -p 443 zero.webappsecurity.com
Starting Nmap 7.90SVN ( https://nmap.org ) at 2022-07-12 11:29 UTC
Nmap scan report for zero.webappsecurity.com (54.82.22.214)
Host is up (0.18s latency).
DNS record for 54.82.22.214: ec2-54-82-22-214.compute-1.amazonaws.com
Not shown: 997 filtered tcp ports (no responses)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache/2.4.18 (Ubuntu)
443/tcp   open  https     Apache/2.4.18 (Ubuntu)
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Zero - Personal Banking - Loans - Credit Cards
|_ http-methods:
|_ Potentially risky methods: PUT DELETE TRACE PATCH
|_ ssl:
|_   sslv2:
|_     supported
|_     ciphers:
|_       SSLv2_DES_64_CBC_WITH_MD5
|_       SSLv2_RC2_128_CBC_WITH_MD5
|_       SSLv2_DES_192_CBC_WITH_MD5
|_       SSLv2_RC2_128_EXPORT40_WITH_MD5
|_       SSLv2_RC2_128_CBC_EXPORT40_WITH_MD5
|_   _ssl-date: 2022-07-12T11:29:00Z, -1s from scanner time.
|_   _ssl-cert: Subject: commonName=zero.webappsecurity.com/organizationName=Micro Focus LLC/stateOrProvinceName=California/countryName=US
|_   Subject Alternative Name: DNS:zero.webappsecurity.com
|_   Not valid before: 2021-04-20T00:00:00
|_   Not valid after: 2022-05-04T23:59:59
|_   _ssl-protocol:
|_     http:
|_       Apache/2.4.18 (Ubuntu)
|_       http-methods:
|_         Potentially risky methods: PUT DELETE TRACE PATCH
|_         http-server-header: Apache/2.4.18 (Ubuntu)
Host script results:
|_ _clock-skew: -1s
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.40 seconds
vishal@LAPTOP-3VUES001:~$

```

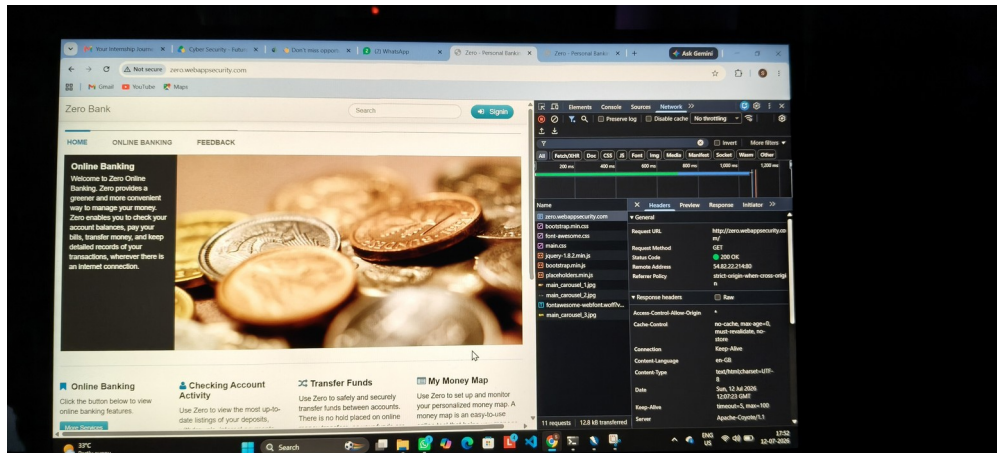
Nmap service scan: SSLv2 supported with weak ciphers; certificate "Not valid after: 2022-05-04"

Recommendation:- Disable SSLv2 and SSLv3 along with all legacy/export ciphers. Install a current SSL/TLS certificate from a trusted certificate authority and renew it before expiry. Force all HTTP traffic to redirect to HTTPS.

3) Insecure Connection and Missing Security Headers (Medium)

Description	The application's homepage loads over plain "http" instead of "https", and the browser flags the connection as Not Secure. The response also lacks standard protective headers such as Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options.
Impact	Medium
System	http://zero.webappsecurity.com/

Proof of concept:



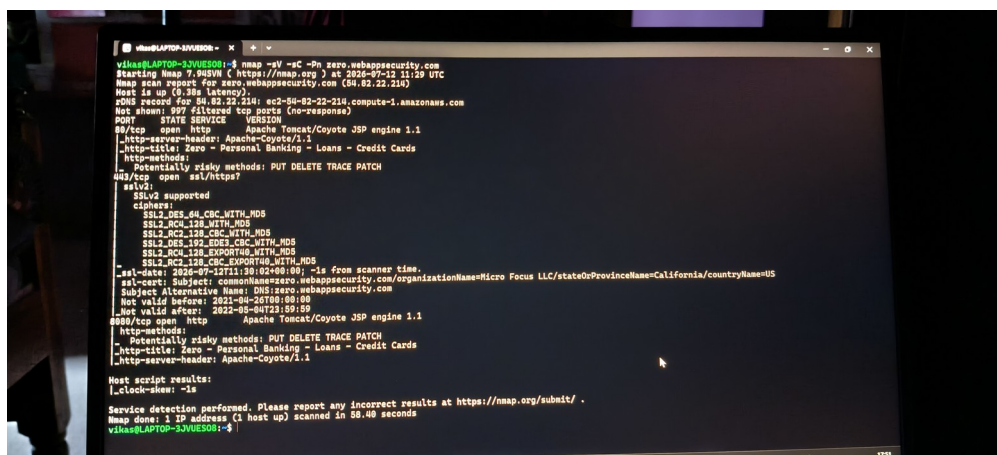
Chrome DevTools: browser "Not secure" warning on <http://zero.webappsecurity.com> and response headers reviewed in the Network tab

Recommendation:- Move the entire site to HTTPS with a valid certificate and redirect all HTTP requests. Add the standard protective response headers: Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options.

4) Server Version Disclosure and Risky HTTP Methods (Medium)

Description	The web server openly reports its exact software version (Apache-Coyote/1.1) in the Server response header, and several rarely-needed HTTP methods (PUT, DELETE, TRACE, PATCH) remain enabled on the server.
Impact	Medium
System	http://zero.webappsecurity.com/ (ports 80, 8080)

Proof of concept:



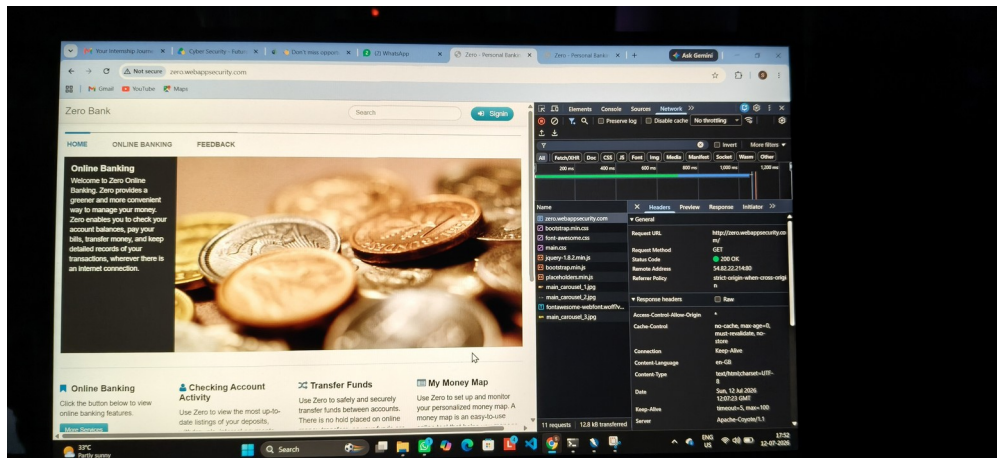
Nmap service scan: "Server: Apache-Coyote/1.1" banner and "Potentially risky methods: PUT DELETE TRACE PATCH"

Recommendation:- Suppress or generalize the server version banner in the web server configuration, and disable unused HTTP methods (PUT, DELETE, TRACE, PATCH) unless explicitly required.

5) Outdated JavaScript Library (jQuery 1.8.2) (Medium)

Description	The application loads jQuery version 1.8.2, released in 2012, which has multiple publicly documented vulnerabilities. Outdated client-side libraries are a common vector for cross-site scripting and related attacks.
Impact	Medium
System	http://zero.webappsecurity.com/ (jquery-1.8.2.min.js)

Proof of concept:



Chrome DevTools Network tab: jquery-1.8.2.min.js loaded from the homepage

Recommendation:- Upgrade jQuery (and all third-party JavaScript libraries) to a current, supported version, and establish a regular patch cycle to keep dependencies up to date.

Summary

Two High-risk findings — SQL Injection in the search function and outdated/expired SSL-TLS encryption — allow direct exposure of sensitive data and should be remediated immediately. The remaining three Medium-risk findings weaken the application's overall security posture and should be addressed in the next release or patch cycle.